

SPECIAL PUBLICATION (SOAR PLAYBOOK)

Automated Phishing Incident Triage Playbook

Splunk SOAR (Phantom) Implementation

Michael Asante Anim

July 29, 2026

Abstract

This playbook defines an automated, auditable workflow for triaging phishing incidents using Splunk SOAR (Phantom), aligned to the four-phase incident response lifecycle in NIST SP 800-61 Revision 2 (Preparation; Detection and Analysis; Containment, Eradication, and Recovery; Post-Incident Activity) and cross-mapped to the six-phase SANS Incident Handler's Handbook model. The playbook automates enrichment of indicators of compromise (sender reputation, SPF/DKIM/DMARC results, sandbox detonation, and threat intelligence lookups per NIST SP 800-150), applies risk-based human-in-the-loop checkpoints consistent with NIST SP 800-53 Revision 5 controls IR-4 and IR-5, and preserves forensic evidence prior to destructive containment actions per NIST SP 800-86. Decision logic, containment actions, and metrics captured (MTTD, MTTR, false-positive rate) are mapped to MITRE ATT&CK technique T1566 (Phishing) and its sub-techniques. The design emphasizes idempotency, fail-safe defaults, full auditability, and version-controlled playbook-as-code to support repeatable, defensible incident handling.

Keywords

incident response; SOAR; security orchestration automation and response; phishing; NIST SP 800-61; NIST SP 800-53; NIST SP 800-150; NIST SP 800-86; MITRE ATT&CK; T1566; playbook automation; SANS Incident Handler's Handbook; threat intelligence enrichment; human-in-the-loop; forensic evidence preservation.

Acknowledgements

The author acknowledges the frameworks and standards bodies whose published guidance underpins this playbook, including the National Institute of Standards and Technology (NIST) Special Publications 800-61 Revision 2, 800-53 Revision 5, 800-150, and 800-86; the MITRE Corporation for the ATT&CK and D3FEND knowledge bases; and the SANS Institute for the Incident Handler's Handbook. The author also acknowledges the University of Mines and Technology (UMaT) Cybersecurity Club and the Department of Cyber Security for supporting the practical and academic work that informed this document.

Table of Contents

Contents

1	Introduction	7
1.1	Authority	7
1.2	Purpose and Scope	7
1.3	Audience	7
1.4	Document Structure	7
2	Metadata / Header	8
3	Organizing a Computer Security Incident Response Capability	9
3.1	Events and Incidents	9
3.2	Need for Incident Response	9
3.3	Incident Response Team Structure	9
3.3.1	Team Model Selection	9
3.4	Incident Response Team Services	9
4	Trigger & Scope	10
4.1	Detection Rule / Alert Type	10
4.2	False-Positive Filter Conditions	10
4.3	Applicable Asset Scope	10
4.4	Incident Response Life Cycle (NIST SP 800-61r2, Figure 3-1)	10
5	Lifecycle Phases	12
5.1	Model Alignment	12
5.2	Where the Models Diverge	12
6	Automated Enrichment (Triage Phase)	13
6.1	Context Auto-Pull	13
6.2	Threat Intelligence Lookups	13
6.3	IOC Extraction and Reputation Scoring	13
6.4	Historical Correlation	13
6.5	Sandbox Detonation	14
7	Decision Logic	15
7.1	Branching Logic	15
7.2	Human-in-the-Loop Checkpoints	15
7.3	Fail-Safe Default	15
8	Containment / Response Actions	16
8.1	Automated Actions	16
8.2	Evidence Preservation / Chain of Custody	16
8.3	Action Logging Schema	16
9	Eradication & Recovery	18
9.1	Remove Malicious Artifacts Org-Wide	18

9.2	Close the Root Vulnerability / Re-Entry Vector	18
9.3	Conditions for Restoring Normal Operations	18
9.4	Heightened Monitoring Period	18
10	Communication & Escalation	19
10.1	Notification Matrix	19
10.2	SLA Timers per Severity Tier	19
11	Documentation & Closure	20
11.1	Auto-Generated Case Notes / Timeline	20
11.2	Root Cause Tagging	20
11.3	Metrics Captured	20
12	Post-Incident Activity	21
12.1	Lessons-Learned Trigger	21
12.2	Playbook Feedback Loop	21
13	Design Principles	22
13.1	Idempotency	22
13.2	Fail-Safe Defaults	22
13.3	Auditability	22
13.4	Modularity	22
13.5	Version Control	22
13.6	Playbook Execution Flow	22
14	Full Reference List	24

Executive Summary

Phishing remains the most common initial access vector observed across enterprise environments, mapped to MITRE ATT&CK technique T1566 and its sub-techniques. Manual triage of phishing alerts does not scale: analysts spend disproportionate time on repetitive enrichment tasks (reputation lookups, header analysis, sandbox submission) rather than on judgment-driven decisions that require human expertise. This playbook closes that gap by automating the repeatable portion of triage in Splunk SOAR (Phantom) while preserving human control over high-impact, potentially destructive actions.

Key outcomes of this playbook:

- **Faster triage:** automated enrichment (sender reputation, SPF/DKIM/DMARC validation, IOC extraction, sandbox detonation, and threat-intelligence correlation) completes within minutes of alert ingestion, reducing Mean Time to Detect (MTTD).
- **Consistent decisions:** conditional branching applies the same confidence thresholds every time, removing analyst-to-analyst variance in low-complexity cases.
- **Controlled automation:** destructive or high-impact actions (org-wide quarantine, domain blocking, host isolation, account disablement) require analyst approval, per the risk-based control guidance in NIST SP 800-53 Revision 5, IR-4 and IR-5.
- **Defensible evidence handling:** forensic artifacts are preserved prior to containment, consistent with NIST SP 800-86, to support downstream investigation or legal process.
- **Continuous improvement:** every incident closes with auto-generated case notes, root-cause tagging, and metrics (MTTD, MTTR, false-positive rate) that feed a Lessons Learned loop per NIST SP 800-61 Revision 2, Section 3.4.

The remainder of this document specifies the playbook's trigger conditions, lifecycle mapping, enrichment logic, decision trees, containment actions, communication procedures, and the design principles (idempotency, fail-safe defaults, auditability, modularity, version control) that distinguish this playbook from an ad hoc or GUI-only automation.

1 Introduction

1.1 Authority

This playbook is issued under the authority of the organization's Security Operations Center (SOC) charter and Incident Response Policy, and implements the incident handling guidance established in NIST Special Publication 800-61 Revision 2, *Computer Security Incident Handling Guide*. Where applicable, security control selection is informed by NIST SP 800-53 Revision 5, *Security and Privacy Controls for Information Systems and Organizations*, specifically the Incident Response (IR) control family.

1.2 Purpose and Scope

The purpose of this document is to define a repeatable, auditable, and partially automated workflow for triaging phishing-based security incidents within Splunk SOAR (Phantom). The playbook covers the full incident lifecycle from initial alert ingestion through containment, eradication, recovery, and post-incident review, as it applies specifically to phishing delivered via email (MITRE ATT&CK T1566 and sub-techniques). This document does *not* cover non-email initial access vectors (e.g., drive-by compromise, removable media) or incident types outside phishing, though the enrichment and containment sub-playbooks referenced herein are designed to be reusable across other playbook families.

1.3 Audience

This document is intended for:

- SOC Tier 1 and Tier 2 analysts executing or reviewing playbook actions;
- Incident Response (IR) leads responsible for escalation decisions and post-incident review;
- Security engineers maintaining or extending the playbook logic within Splunk SOAR;
- Auditors and compliance stakeholders verifying that incident handling follows documented, standards-aligned procedures.

1.4 Document Structure

The remainder of this document is organized as follows: Section 2 defines playbook metadata and classification; Section 3 covers organizing the incident response capability; Section 4 specifies trigger conditions and scope; Section 5 maps the playbook to the NIST and SANS incident lifecycle models; Section 6 details automated enrichment logic; Section 7 defines decision logic and escalation thresholds; Section 8 covers containment and response actions; Section 9 addresses eradication and recovery; Section 10 defines communication and escalation procedures; Section 11 covers documentation and closure; Section 12 addresses post-incident activity; Section 13 states the design principles underlying this playbook; and Section 14 provides the full reference list.

2 Metadata / Header

Field	Value
Playbook ID	SOAR-PB-PHISH-001
Version	1.0.0
Author	Michael Asante Anim
Last Reviewed	July 29, 2026
Platform	Splunk SOAR (Phantom)
Trigger Source	Email security gateway alert; SIEM correlation alert; user-reported phishing (Report Phishing add-in / abuse mailbox)
Severity Classification	Per NIST SP 800-61r2 §3.2.6 — assessed across three axes: Functional Impact (effect on business operations), Information Impact (confidentiality/integrity of data), Recoverability Effort (time/resources to recover)
MITRE ATT&CK Mapping	T1566 (Phishing); T1566.001 (Spearphishing Attachment); T1566.002 (Spearphishing Link); T1566.003 (Spearphishing via Service) — attack.mitre.org/techniques/T1566
Owning Team	SOC Tier 1/2 (execution); IR Lead (escalation authority)
Escalation Contact	IR Lead on-call rotation (PagerDuty); CISO for Severity Critical

Primary Reference: NIST SP 800-61 Rev. 2, Section 3.2.6 — *Incident Prioritization*. Severity is not a single score but a composite of Functional Impact (None/Low/Medium/High), Information Impact (None/Privacy Breach/Proprietary Breach/Integrity Loss), and Recoverability Effort (Regular/Supplemented/Extended/Not Recoverable).

3 Organizing a Computer Security Incident Response Capability

3.1 Events and Incidents

Per NIST SP 800-61 Revision 2, Section 2.1, an *event* is any observable occurrence in a system or network, while a *computer security incident* is a violation or imminent threat of violation of security policies, acceptable use policies, or standard security practices. In the context of this playbook, a phishing *event* is any inbound message flagged by the email gateway, SIEM correlation rule, or user report. It escalates to a phishing *incident* once triage confirms malicious intent or impact — e.g., a credential-harvesting link, a malicious attachment, or evidence that a user interacted with the payload.

3.2 Need for Incident Response

Phishing is the leading initial access vector mapped to MITRE ATT&CK T1566, and email volume makes fully manual triage unsustainable at enterprise scale. NIST SP 800-61 Revision 2, Section 2.2 notes that an incident response capability reduces loss, contains scope, and shortens recovery time. Automating the repeatable portion of phishing triage in Splunk SOAR directly serves this need by compressing Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR) while preserving analyst judgment for ambiguous or high-impact cases.

3.3 Incident Response Team Structure

3.3.1 Team Model Selection

This playbook assumes a **centralized SOC team model** (NIST SP 800-61 Revision 2, Section 2.4.1–2.4.2), in which Tier 1/2 analysts execute and review automated playbook actions, and an Incident Response (IR) lead holds escalation authority for Severity High/Critical cases. This model was selected for consistency with the single owning team and escalation contact defined in Section 2 (Metadata / Header) of this document; organizations using a distributed or coordinating team model should map the human-in-the-loop checkpoints in Section 8 to their equivalent roles.

3.4 Incident Response Team Services

Consistent with NIST SP 800-61 Revision 2, Section 2.5, the capability supporting this playbook provides, at minimum: intrusion detection and alert triage, incident analysis and enrichment, containment and eradication support, and post-incident reporting. Advisory services such as security awareness training and vulnerability assessment are outside this playbook's scope but are referenced as inputs to the Post-Incident Activity phase (Section 12).

4 Trigger & Scope

4.1 Detection Rule / Alert Type

This playbook is triggered by any of the following:

- Email security gateway verdict of "suspicious" or "malicious" (e.g., Proofpoint, Mimecast, Microsoft Defender for Office 365);
- SIEM correlation rule matching phishing indicators (spoofed sender domain, known-bad URL/IP, anomalous authentication following email delivery);
- User-reported phishing via the "Report Phishing" mail add-in or submission to the abuse mailbox.

4.2 False-Positive Filter Conditions

The playbook auto-closes without analyst review only if *all* of the following hold:

- Sender domain and URLs return clean reputation across all configured threat intelligence sources;
- SPF, DKIM, and DMARC all pass;
- No attachment present, or attachment hash matches an organization-approved allow-list;
- No prior report of the same sender/IOC within the last 90 days.

If any condition fails, the incident proceeds to Automated Enrichment (Section 6) rather than auto-closing.

4.3 Applicable Asset Scope

- **Mailboxes:** all organizational mailboxes reachable via the email security gateway API;
- **Endpoints:** any endpoint associated with a user who opened an attachment or clicked a link from the flagged message;
- **Network segment:** corporate LAN/VPN segments through which affected endpoints communicate; cloud-hosted mail infrastructure (e.g., Exchange Online) is in scope, on-premises legacy mail relays are out of scope for this version.

4.4 Incident Response Life Cycle (NIST SP 800-61r2, Figure 3-1)

Figure 4.4 illustrates the four-phase incident response life cycle defined in NIST SP 800-61 Revision 2, Section 3, which this playbook's phases (Section 5) are mapped against.

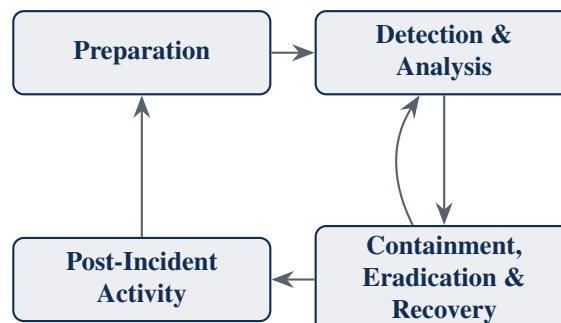


Figure 1: Incident Response Life Cycle, recreated from NIST SP 800-61 Revision 2, Section 3, Figure 3-1. Curved arrow indicates the feedback loop between Detection/Analysis and Containment/Eradication/Recovery during active incident handling.

5 Lifecycle Phases

This playbook’s execution stages are mapped explicitly against two industry-standard incident handling models: the four-phase model in NIST SP 800-61 Revision 2, Section 2.3, and the six-phase model in the SANS Institute’s Incident Handler’s Handbook.

5.1 Model Alignment

NIST SP 800-61r2 (§2.3, four-phase)	SANS IH Handbook (six-phase)	Playbook Activity
Preparation	Preparation	Tooling, playbook-as-code deployment, threat intel feed configuration, sandbox integration, escalation contact roster maintenance.
Detection & Analysis	Identification	Alert ingestion, false-positive filtering, initial triage (Section 4).
	Identification (cont.)	Automated enrichment: IOC extraction, reputation scoring, sandbox detonation, historical correlation (Section 6).
Containment, Eradication & Recovery	Containment	Email quarantine, sender/domain blocking, URL disabling, host isolation (Section 8).
	Eradication	Org-wide artifact removal, closing the re-entry vector (Section 9).
	Recovery	Restoration validation, heightened monitoring window (Section 9).
Post-Incident Activity	Lessons Learned	Case documentation, metrics capture, root-cause tagging, playbook tuning feedback loop (Sections 11–12).

5.2 Where the Models Diverge

- NIST treats *Containment, Eradication, and Recovery* as a single combined phase (Section 2.3), reflecting that these activities often overlap and iterate rather than execute strictly in sequence. SANS separates them into three distinct phases, which this playbook follows for operational granularity in Sections 8–9, while preserving NIST’s combined-phase terminology for compliance reporting.
- SANS’s *Identification* phase corresponds to NIST’s *Detection and Analysis*, but SANS’s handbook places heavier emphasis on formal incident declaration as a discrete checkpoint; this playbook implements that checkpoint as the transition from Automated Enrichment (Section 6) into Decision Logic (Section 7, human-in-the-loop gate).
- Both models converge on treating post-incident review as essential and non-optional; this playbook enforces that convergence by auto-triggering a Lessons Learned task (Section 12) on every incident closure, regardless of final severity.

6 Automated Enrichment (Triage Phase)

Upon passing the false-positive filter (Section 4.2), Splunk SOAR executes the following enrichment sequence automatically, without analyst intervention, before any decision logic (Section 7) is evaluated.

6.1 Context Auto-Pull

- **Sender reputation:** sender email address, sending IP, and originating mail server queried against configured reputation sources.
- **User identity:** recipient identity resolved via directory lookup (Active Directory / Azure AD) to determine department, role, and privilege level.
- **Asset criticality:** if the recipient's endpoint is identified, its criticality tier is pulled from the asset management system (CMDB) to weight downstream severity scoring.

6.2 Threat Intelligence Lookups

Per NIST SP 800-150, *Guide to Cyber Threat Information Sharing*, Section 4, indicator enrichment should draw on multiple independent sources to reduce false-positive risk from any single feed. This playbook queries:

- **VirusTotal** — file hash and URL reputation, detection ratio across AV engines;
- **AbuseIPDB** — sending IP abuse confidence score;
- **MISP** — internal/community threat intel platform, checked for matching indicators from prior campaigns.

6.3 IOC Extraction and Reputation Scoring

The playbook extracts and scores the following indicators from the message:

- URLs (including redirect chains, unshortened);
- Attachment file hashes (MD5/SHA-256);
- Sender domain and header `From/Reply-To` mismatch;
- SPF, DKIM, and DMARC authentication results.

Each IOC receives a normalized reputation score (0–100, where 100 is maximum confidence malicious) aggregated across all queried sources.

6.4 Historical Correlation

The playbook queries the case management system for prior incidents involving the same sender, domain, URL, or file hash within the last 90 days. A prior confirmed-malicious match on any IOC immediately raises the aggregate confidence score, regardless of current reputation-source results, since evasive infrastructure often cycles reputation faster than feeds update.

6.5 Sandbox Detonation

Any attachment or linked file that is not on the organizational allow-list is automatically submitted for sandbox detonation. Detonation results (process tree, network callbacks, registry/file system modifications) are attached to the case record and factored into the aggregate confidence score before Decision Logic (Section 7) executes.

Enrichment Output

At the end of this phase, every case carries: an aggregate malicious confidence score (0–100), a full IOC list with per-source reputation results, sandbox verdict (if applicable), and identity/asset context. This output is the sole input to the conditional branching logic in Section 7.

7 Decision Logic

Conditional branching consumes the aggregate confidence score and context produced in Section 6. Per NIST SP 800-53 Revision 5, control IR-4 (Incident Handling), organizations must select response actions commensurate with incident impact; control IR-5 (Incident Monitoring) requires that incident status be tracked through resolution. This playbook implements both by gating high-impact actions behind an analyst approval checkpoint rather than allowing full auto-remediation.

7.1 Branching Logic

If/Then Decision Tree

IF aggregate confidence score < 25 **AND** no sandbox detonation flagged malicious **AND** no historical match:

THEN auto-close as false positive; log rationale; no analyst action required.

IF aggregate confidence score $\geq$ 25 **AND** < 60:

THEN route to SOC Tier 1 analyst queue for manual review; no automated containment action taken; SLA timer starts (Section 10).

IF aggregate confidence score $\geq$ 60 **AND** < 85:

THEN auto-execute low-impact, reversible containment (quarantine the specific message org-wide; disable the specific malicious URL); route to SOC Tier 2 analyst for approval before any further action (host isolation, account actions).

IF aggregate confidence score $\geq$ 85 **OR** sandbox detonation confirms malicious execution **OR** historical match confirms known-malicious infrastructure:

THEN escalate immediately to IR Lead; present full high-impact containment action set (Section 8) for one-click analyst approval; do *not* auto-execute destructive actions without approval, per the fail-safe default principle (Section 13).

7.2 Human-in-the-Loop Checkpoints

Per NIST SP 800-53 Revision 5, IR-4, the following actions always require explicit analyst approval regardless of confidence score, because they are high-impact, potentially disruptive, or difficult to reverse:

- Endpoint isolation from the network;
- User account disablement or forced credential reset;
- Organization-wide sender domain or IP blocking (as opposed to single-message quarantine);
- Any action affecting a critical-tier asset, regardless of confidence score.

This checkpoint is logged as a discrete, timestamped approval event per IR-5 monitoring requirements, capturing the analyst identity, decision, and timestamp for audit purposes.

7.3 Fail-Safe Default

If any enrichment source (Section 6) is unavailable or times out, the playbook does *not* default to the highest-confidence branch. It instead routes the case to manual analyst review with a flag indicating incomplete enrichment, consistent with the fail-safe default design principle in Section 13.

8 Containment / Response Actions

All containment actions in this section are triggered by the branching logic in Section 7 and are subject to the human-in-the-loop checkpoints defined therein. Every action is logged with what was done, when, and by whom (system automation vs. named analyst), consistent with the auditability principle in Section 13.

8.1 Automated Actions

Action	Trigger Condition	Rollback Method
Quarantine email org-wide	Confidence $\geq$ 60; message matches known-malicious IOC	Restore from quarantine via case ID; requires analyst approval
Block sender domain/IP	Confidence $\geq$ 85 or IR Lead approval	Remove entry from block list; logged as a discrete reversal action
Disable malicious URL	Confidence $\geq$ 60	Re-enable via threat intel platform if determined benign on review
Isolate host (if attachment executed)	Sandbox confirms execution AND analyst approval (IR-4 checkpoint)	Endpoint management console; requires analyst-confirmed clean scan before release
Disable/reset compromised account	Evidence of credential submission to phishing page AND analyst approval	Directory admin re-enables account after mandatory password reset and MFA re-enrollment

8.2 Evidence Preservation / Chain of Custody

Per NIST SP 800-86, *Guide to Integrating Forensic Techniques into Incident Response*, Section 3, evidence must be preserved in a manner that maintains its integrity for potential investigative or legal use. Before any destructive containment action executes, the playbook automatically:

- Captures a full copy of the original message (headers, body, attachments) with cryptographic hash for integrity verification;
- Archives sandbox detonation artifacts (process tree, network captures, memory snapshot if available);
- Logs the case timeline with UTC timestamps for every automated and analyst-driven action;
- Assigns a unique evidence identifier tied to the case ID, stored in a write-once evidence repository separate from the live mailbox.

This preservation step executes *before* quarantine, blocking, or isolation actions to ensure evidence is not altered or lost as a side-effect of containment.

8.3 Action Logging Schema

Every containment action writes a structured log entry containing: action type, trigger condition met, executing actor (system automation identifier or named analyst), UTC timestamp, target asset/IOC, and rollback

reference. This schema satisfies the auditability requirement in Section 13 and supports the metrics captured at closure (Section 11).

9 Eradication & Recovery

Eradication and Recovery follow confirmed containment (Section 8) and correspond to the combined NIST SP 800-61 Revision 2 Section 2.3 phase and the separate SANS Eradication/Recovery phases mapped in Section 5.

9.1 Remove Malicious Artifacts Org-Wide

- Search-and-purge of the identical message across all organizational mailboxes (not limited to the originally reported recipient), using message hash and sender/subject fingerprint;
- Removal of any dropped files or persistence artifacts identified by sandbox detonation (Section 6.5) from affected endpoints, executed via endpoint management tooling;
- Revocation of any OAuth tokens or app consents granted to a malicious application if the phishing vector was consent-phishing rather than credential harvesting.

9.2 Close the Root Vulnerability / Re-Entry Vector

- If the phishing message bypassed email gateway filtering due to a rule gap, update gateway detection rules and submit the sample to the vendor for signature update;
- If credential harvesting succeeded, enforce mandatory MFA re-enrollment for the affected account in addition to password reset;
- If a browser or endpoint vulnerability enabled attachment execution, confirm patch status and remediate via vulnerability management workflow.

9.3 Conditions for Restoring Normal Operations

Normal operations are restored only when *all* of the following are validated by an analyst:

- Endpoint scan confirms no residual malicious artifacts;
- Affected account shows no anomalous authentication activity post-remediation;
- Root cause (detection gap, user action, unpatched vulnerability) has been identified and a remediation ticket opened if not immediately resolvable;
- Evidence package (Section 8.2) is finalized and archived.

9.4 Heightened Monitoring Period

Following recovery, the playbook automatically applies a 14-day heightened monitoring window on the affected account and endpoint: authentication anomaly alerts are lowered in threshold sensitivity, and any recurrence of the same IOC family triggers immediate escalation to IR Lead without re-running the standard confidence-scoring branch in Section 7.

10 Communication & Escalation

Notification and SLA timing are driven by the severity classification established in Section 2 (Metadata / Header), per NIST SP 800-61 Revision 2, Section 3.2.6.

10.1 Notification Matrix

Severity	SOC Tier 1/2	IR Lead	Management / CISO
Low	Case logged; no notification	Not notified	Not notified
Medium	Notified via case queue	Notified via case queue	Not notified
High	Notified immediately (Slack/Teams)	Notified immediately (Slack/Teams + page)	Notified via daily digest
Critical	Notified immediately	Paged immediately	Notified immediately; briefing scheduled within 4 hours

10.2 SLA Timers per Severity Tier

Severity	Acknowledgment SLA	Containment Action SLA
Low	24 hours	N/A (auto-closed)
Medium	4 hours	8 hours
High	30 minutes	2 hours
Critical	15 minutes	1 hour

SLA timers start at the moment Decision Logic (Section 7) assigns the severity tier, not at initial alert ingestion, so that automated enrichment time (Section 6) does not count against analyst response SLAs. Timer breaches automatically escalate to the next tier in the notification matrix.

11 Documentation & Closure

Per NIST SP 800-61 Revision 2, Section 3.4, *Incident Handling Checklist*, every incident must be fully documented before closure to support post-incident review and organizational metrics tracking.

11.1 Auto-Generated Case Notes / Timeline

Splunk SOAR automatically compiles a chronological case record containing:

- Initial trigger event (Section 4.1) with UTC timestamp;
- Full enrichment output (Section 6): confidence score, IOC list, sandbox verdict, historical correlation results;
- Decision branch taken (Section 7) and rationale;
- Every containment action executed (Section 8), with actor and timestamp;
- Evidence preservation references (Section 8.2);
- Eradication and recovery validation steps (Section 9);
- All analyst approval/rejection events with identity and timestamp.

This timeline is generated automatically as actions occur, not reconstructed retroactively, to minimize documentation gaps and analyst overhead.

11.2 Root Cause Tagging

Each closed case is tagged with a standardized root cause category to support trend analysis:

- **Detection gap** — email gateway or SIEM rule failed to flag on initial delivery;
- **User action** — user clicked a link, opened an attachment, or submitted credentials;
- **Technical vulnerability** — unpatched software enabled payload execution;
- **False positive** — benign message incorrectly flagged;
- **Repeat offender** — matches a previously seen campaign or infrastructure (Section 6.4).

11.3 Metrics Captured

Consistent with NIST SP 800-61 Revision 2, Section 3.4, the following metrics are captured automatically at closure and aggregated for reporting:

- **MTTD (Mean Time to Detect)**: time from message delivery to alert trigger (Section 4.1);
- **MTTR (Mean Time to Respond/Remediate)**: time from alert trigger to eradication/recovery validation (Section 9.3);
- **Number of users affected**: count of mailboxes/endpoints in scope per Section 4.3;
- **False-positive rate**: proportion of cases auto-closed or analyst-dismissed as benign (Section 7.1) relative to total cases triggered, tracked over a rolling 30-day window.

12 Post-Incident Activity

Post-Incident Activity closes the NIST SP 800-61 Revision 2 four-phase loop (Section 4.4, Figure 1) and corresponds to the SANS Lessons Learned phase (Section 5).

12.1 Lessons-Learned Trigger

A Lessons Learned review is automatically scheduled for:

- Every incident closed at Severity High or Critical (Section 10.1), within 5 business days of closure;
- Any incident where the fail-safe default (Section 7.3) was invoked due to enrichment source failure;
- Any incident where a human-in-the-loop checkpoint (Section 7.2) rejected the automated recommendation, to evaluate whether decision thresholds need adjustment;
- A rolling monthly review of all Low/Medium severity cases in aggregate, rather than individually, to identify systemic patterns.

12.2 Playbook Feedback Loop

Findings from Lessons Learned reviews feed directly back into playbook tuning:

- **Detection tuning:** if root-cause tagging (Section 11.2) shows a recurring detection gap, the triggering rule (Section 4.1) is updated and version-controlled (Section 13);
- **Threshold tuning:** if false-positive rate (Section 11.3) trends upward for a given confidence band, the branching thresholds in Section 7.1 are reviewed and adjusted;
- **Enrichment source review:** repeated fail-safe invocations (Section 7.3) trigger a review of the affected threat intelligence source's reliability and, if needed, replacement or addition of a redundant source per NIST SP 800-150;
- **Checkpoint review:** repeated analyst rejections at a human-in-the-loop checkpoint (Section 7.2) may indicate the automated recommendation logic requires retraining or the checkpoint criteria require adjustment.

All playbook changes resulting from this feedback loop follow the version control practice defined in Section 13.5.

13 Design Principles

The following principles distinguish this playbook from an ad hoc or GUI-only automation and are enforced throughout Sections 6–12.

13.1 Idempotency

Every automated action checks current state before executing (e.g., confirming a message is not already quarantined before issuing a quarantine command). Re-running the playbook against the same case ID produces no duplicate actions or side effects.

13.2 Fail-Safe Defaults

As established in Section 7.3, automation errs toward human review, not destructive auto-action, whenever enrichment data is incomplete or a source is unavailable. No action classified as high-impact (Section 7.2) ever executes without explicit analyst approval.

13.3 Auditability

Every automated step is logged with UTC timestamp, actor (system vs. named analyst), and action detail, per the schema defined in Section 8.3. This produces a complete, non-repudiable case timeline (Section 11.1) suitable for compliance audit.

13.4 Modularity

Enrichment (Section 6), containment actions (Section 8), and evidence preservation (Section 8.2) are implemented as reusable sub-playbooks (e.g., `enrich_ioc`, `preserve_evidence`, `quarantine_message`) callable from other playbook families beyond phishing, avoiding logic duplication.

13.5 Version Control

This playbook is stored as code (YAML/JSON export from Splunk SOAR) in a git repository, not maintained solely through the GUI. Changes resulting from the feedback loop (Section 12.2) are submitted as pull requests, reviewed, and tagged with a version number consistent with the metadata in Section 2.

13.6 Playbook Execution Flow

Figure 13.6 summarizes the end-to-end decision flow across Sections 4–9.

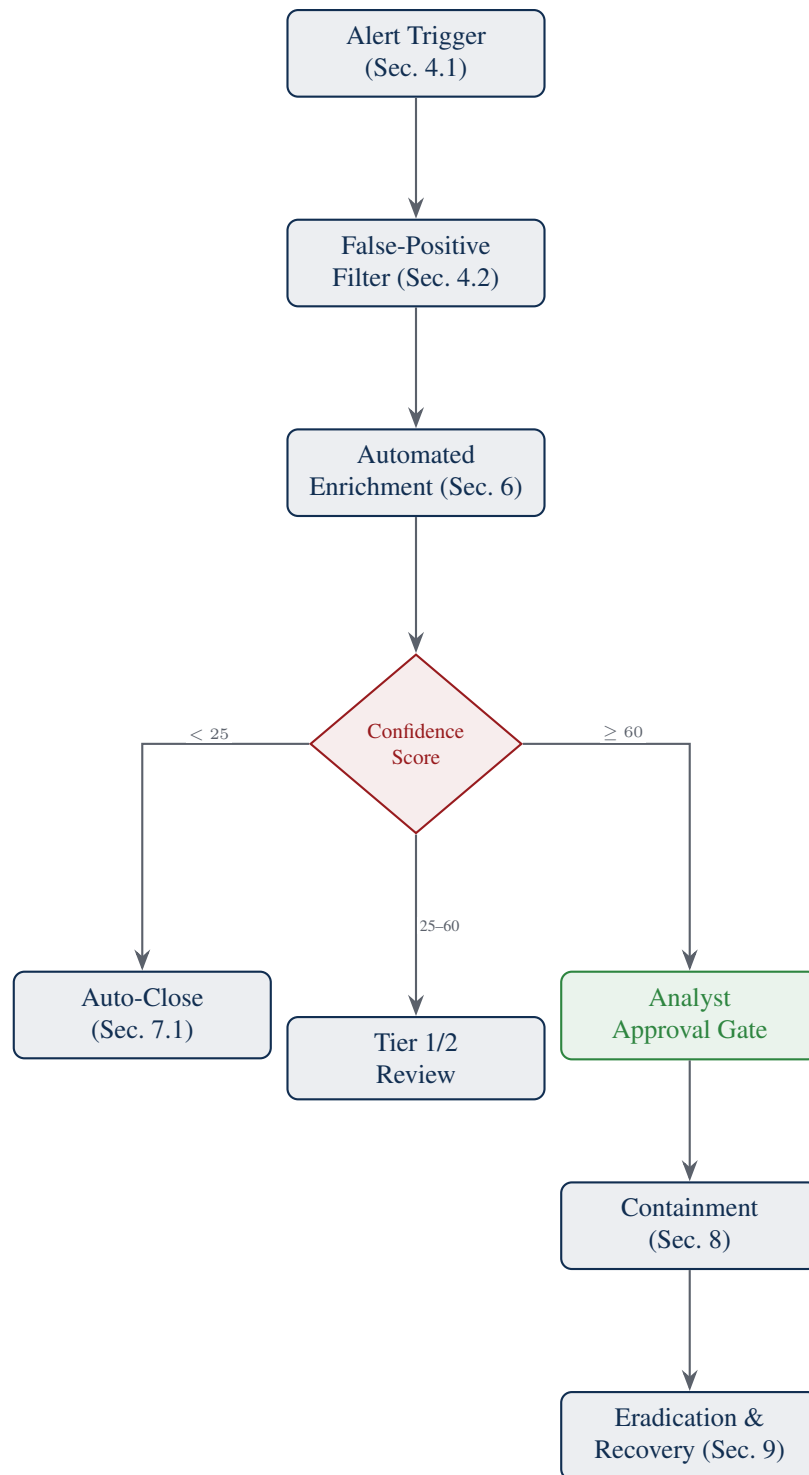


Figure 2: Playbook execution flow from trigger through containment and recovery, showing the three confidence-score branches defined in Section 7.1.

14 Full Reference List

1. National Institute of Standards and Technology. *NIST Special Publication 800-61 Revision 2: Computer Security Incident Handling Guide*. U.S. Department of Commerce, 2012.
2. National Institute of Standards and Technology. *NIST Special Publication 800-150: Guide to Cyber Threat Information Sharing*. U.S. Department of Commerce, 2016.
3. National Institute of Standards and Technology. *NIST Special Publication 800-86: Guide to Integrating Forensic Techniques into Incident Response*. U.S. Department of Commerce, 2006.
4. National Institute of Standards and Technology. *NIST Special Publication 800-53 Revision 5: Security and Privacy Controls for Information Systems and Organizations*. U.S. Department of Commerce, 2020.
5. MITRE Corporation. *MITRE ATT&CK for Enterprise*. <https://attack.mitre.org>.
6. MITRE Corporation. *MITRE D3FEND Matrix*. <https://d3fend.mitre.org>.
7. SANS Institute. *Incident Handler's Handbook*. SANS Reading Room.

Citation Note: Every framework-tied claim in this playbook cites the specific document and section (e.g., NIST SP 800-61r2 §3.2.6, NIST SP 800-53r5 IR-4/IR-5) rather than referencing the framework generically, consistent with the sourcing standard applied throughout Sections 1–13.